

Final Reflective Piece: Information Security Management Module

GitHub Link to e-portfolio: <https://github.com/pecheylauren02/eportfolio-LaurenPechey>

Student Name: Lauren Pechey

Student ID: 12696823

Course: Masters of Computer Science

Module: Information Security Management

Professor: Dr Sabeen Tahir

Word Count: 831 (*excluding reference list*)

New Submission Date: 15 June 2026

Introduction

This reflective essay evaluates my learning across the Information Security Management (ISM) module using Rolfe et al.'s (2001) What? So What? Now What? framework. The module challenged my initial assumption that security is primarily technical, revealing it as a socio-technical discipline where governance, human behaviour, and organisational context are equally significant (Soomro, Shah and Ahmed, 2016; Cram, Proudfoot and D'Arcy, 2017). It also deepened my engagement with compliance and ethical responsibility through ISO/IEC 27001 (2022) and GDPR (European Union, 2016), reinforcing that regulatory adherence does not necessarily equate to effective security.

What?

The most significant learning emerged from the Unit 3 Risk Identification Report and Unit 6 Python-based Attack Tree application. In Unit 3, I acted as a security consultant for Pampered Pets, a small business undergoing digital transformation, identifying vulnerabilities including insecure wireless network design, legacy warehouse systems, and unmanaged staff endpoints. The central challenge was justifying whether digitalisation should proceed, which required comparative evaluation of risk against business value under uncertainty rather than applying a fixed decision rule. This aligned with Hopkin (2018) and ISO/IEC 27005 (2022), who both emphasise that risk evaluation is contextual and shaped by organisational priorities rather than objective measurement.

In Unit 6, I extended this analysis by developing a Python application to model the same threats as an attack tree, assigning monetary values and probabilities to each leaf node and aggregating these into overall risk scores. The results demonstrated a 75% risk reduction post-digitalisation, from £48,000 to £12,000. However, this process exposed a critical limitation I had not anticipated: the precision of a quantitative output depends entirely on subjective inputs, and a monetary figure can create false confidence in what remains an estimate (Aven, 2016; Hubbard and Seiersen, 2016). Xiong and Lagerström (2019) reinforce this, arguing that threat models are interpretive artefacts shaped by analyst assumptions rather than objective security maps. This realisation fundamentally changed how I interpret quantitative risk outputs.

Formative activities also contributed meaningfully. In Unit 2, tutor-led seminar preparation on STRIDE, DREAD, and CVSS deepened my understanding of how threats are categorised, directly informing the modelling decisions in Units 3 and 6. In Unit 4, exploring RPO, RTO, and DRaaS models through structured tutor guidance extended my awareness that risk governance reaches beyond prevention into resilience and continuity planning.

So What?

This module redefined how I understand ISM. Rather than a set of technical controls, it is a discipline requiring structured but inherently interpretive decision-making, where outputs are shaped by assumptions, context, and stakeholder priorities (Whitman and Mattord, 2018; ISO/IEC 27001, 2022).

Collaborative activities were central to this development. In Unit 1, contributing to the collaborative discussion on digitalisation risks required me to take a position and defend it publicly, an experience I found challenging but instructive. In Unit 2, peer reviewing a classmate's post made visible that threat identification is shaped by the analyst's assumptions rather than being neutral or objective, reinforcing that security understanding is co-constructed through shared analysis rather than individual reasoning alone (Aven, 2016). In Units 4 and 5, Wiki contributions on security frameworks and future ISM trends required engagement with diverse perspectives across the cohort, strengthening my ability to critically synthesise competing viewpoints.

Emotionally, the module moved me from early overconfidence in structured models toward a more critical and calibrated mindset. I initially believed that applying the right framework would produce reliable, defensible outputs. The Unit 6 assignment disrupted this view: realising how sensitive the risk scores were to my own probability estimates was unsettling but ultimately productive. It made visible the gap between analytical rigour and epistemic certainty that Aven (2016) identifies as a defining challenge in modern risk practice, shifting my approach from seeking precision to seeking transparency about uncertainty.

Now What?

Moving forward, I aim to apply structured risk frameworks in organisational contexts while maintaining critical awareness of their limitations. My Professional Development Plan reflects this, prioritising threat modelling, secure programming, and governance communication as key competencies. I intend to engage with ISO/IEC 27001 (2022) as a flexible governance tool rather than a compliance checklist, and to develop greater capability in communicating risk outputs to non-technical stakeholders in ways that acknowledge rather than obscure uncertainty (Hopkin, 2018; NIST, 2020). I also intend to build on the Python skills developed in Unit 6, recognising that computational literacy is increasingly central to professional ISM practice.

Conclusion

Applying Rolfe et al.'s (2001) framework enabled structured synthesis of my learning, significance, and development within this module. The Unit 3 and Unit 6 assignments demonstrated that ISM depends on interpretation, context, and judgement rather than purely technical outputs (Hopkin, 2018). Collaborative activities across Units 1, 2, 4, and 5 showed that security understanding is co-constructed through peer interaction and shared analysis. Most significantly, the module challenged my confidence in quantitative risk outputs, developing a more critical awareness of epistemic uncertainty (Aven, 2016) and the need to apply standards such as ISO/IEC 27001 contextually and flexibly rather than prescriptively.

References:

- Aven, T. (2016) 'Risk assessment and risk management: Review of recent advances on their foundation', *European Journal of Operational Research*, 253(1), pp. 1–13.
- Cram, W.A., Proudfoot, J.G. and D'Arcy, J. (2017) 'Organizational information security policies: A review and research framework', *European Journal of Information Systems*, 26(6), pp. 605–641.
- European Union (2016) *Regulation (EU) 2016/679 (General Data Protection Regulation)*. Official Journal of the European Union.
- Hopkin, P. (2018) *Fundamentals of Risk Management*. 5th edn. London: Kogan Page.
- Hubbard, D.W. and Seiersen, R. (2016) *How to Measure Anything in Cybersecurity Risk*. New Jersey: Wiley.
- ISO (2022) *ISO/IEC 27001:2022 Information security management systems — Requirements*. Geneva: ISO.
- ISO (2022) *ISO/IEC 27005:2022 Information security risk management*. Geneva: ISO.
- NIST (2020) *Risk Management Framework for Information Systems and Organizations (SP 800-37 Rev.2)*. Gaithersburg: NIST.
- Rolfe, G., Freshwater, D. and Jasper, M. (2001) *Critical Reflection for Nursing and the Helping Professions: A User's Guide*. Basingstoke: Palgrave Macmillan.
- Soomro, Z.A., Shah, M.H. and Ahmed, J. (2016) 'Information security management needs more holistic approach: A literature review', *International Journal of Information Management*, 36(2), pp. 215–225.
- Whitman, M.E. and Mattord, H.J. (2018) *Management of Information Security*. 6th edn. Boston: Cengage Learning.

Xiong, W. and Lagerström, R. (2019) 'Threat modeling – A systematic literature review',
Computers & Security, 84, pp. 53–69.